

Smart Everything (TRex SE) Software as a Service (SaaS)

Application Info

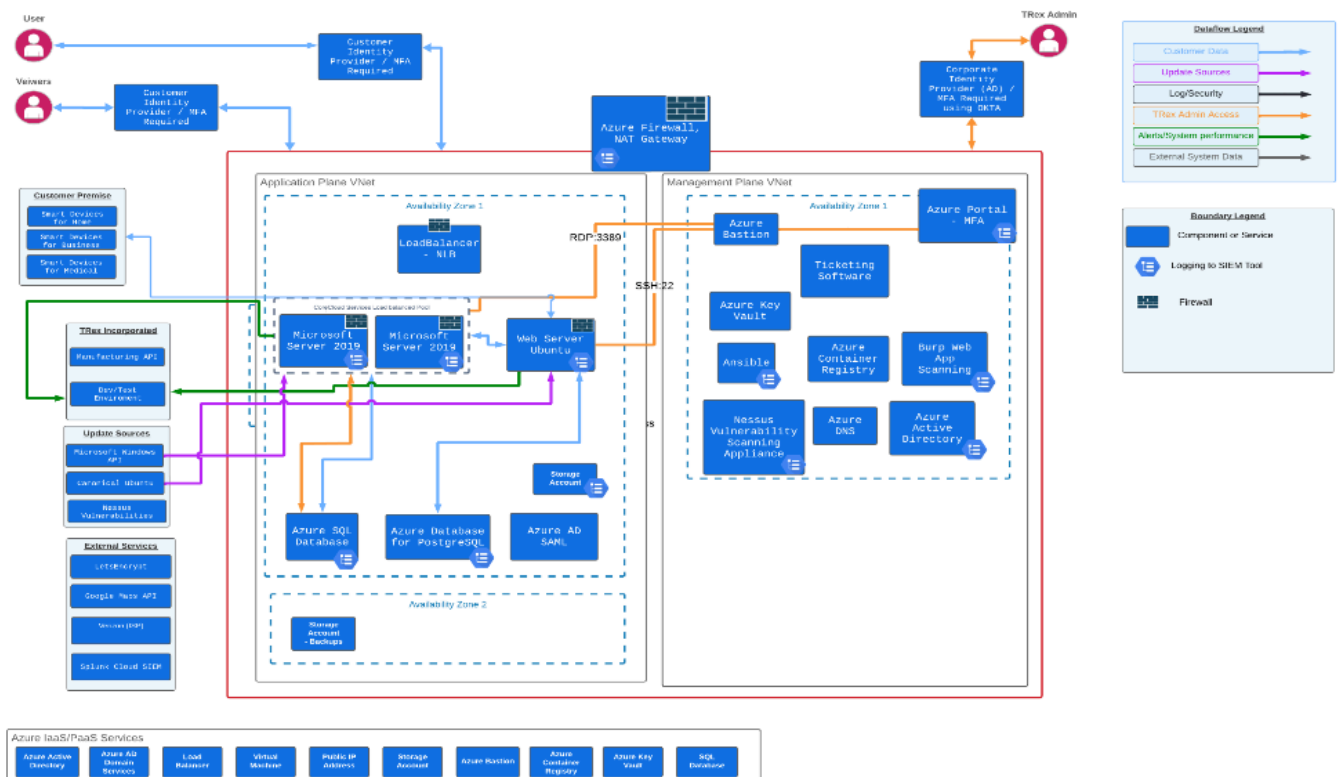
TRex, Inc. develops smart devices to be used for homes and businesses and in the medical industry. These smart devices include alarm systems, appliances, and human-worn devices. They also collect personal identifiable information (PII), protected health information (PHI), credit card information, device and security information, and other sensitive data. The devices can be configured to be linked to first responders, family members, or any authorized users that a business and/or the owner of the device chooses.

Architecture

Introduction

The devices that deploy TRex's software are configured to communicate with the TRex Smart Everything (TRex SE) Software as a Service (SaaS) platform that is hosted on the Azure Commercial Cloud Infrastructure as a Service (IaaS) platform. All TRex administrators log into the management plane of the TRex SE using TRex's active directory configured for multifactor authentication (MFA) using OKTA. Customers must use MFA and must provide their own identity provider (if applicable). All customer users will be configured to use MFA to gain access to their device as well as TRex SE, according to their choice, with no exceptions. FIPS 140-2 validated encryption is used throughout the environment, and all events from each host within the environment are logged and sent to Splunk. Within the TRex SE platform, all technology is updated automatically using advanced programmable interfaces (APIs). The home and business devices use their own internet service provider (ISP); however, due to the sensitive nature of the medical devices and their purposes, TRex will utilize Verizon ISP for internet connectivity with these devices. No data leaves the United States borders per service level agreements (SLA).

Architecture Diagram

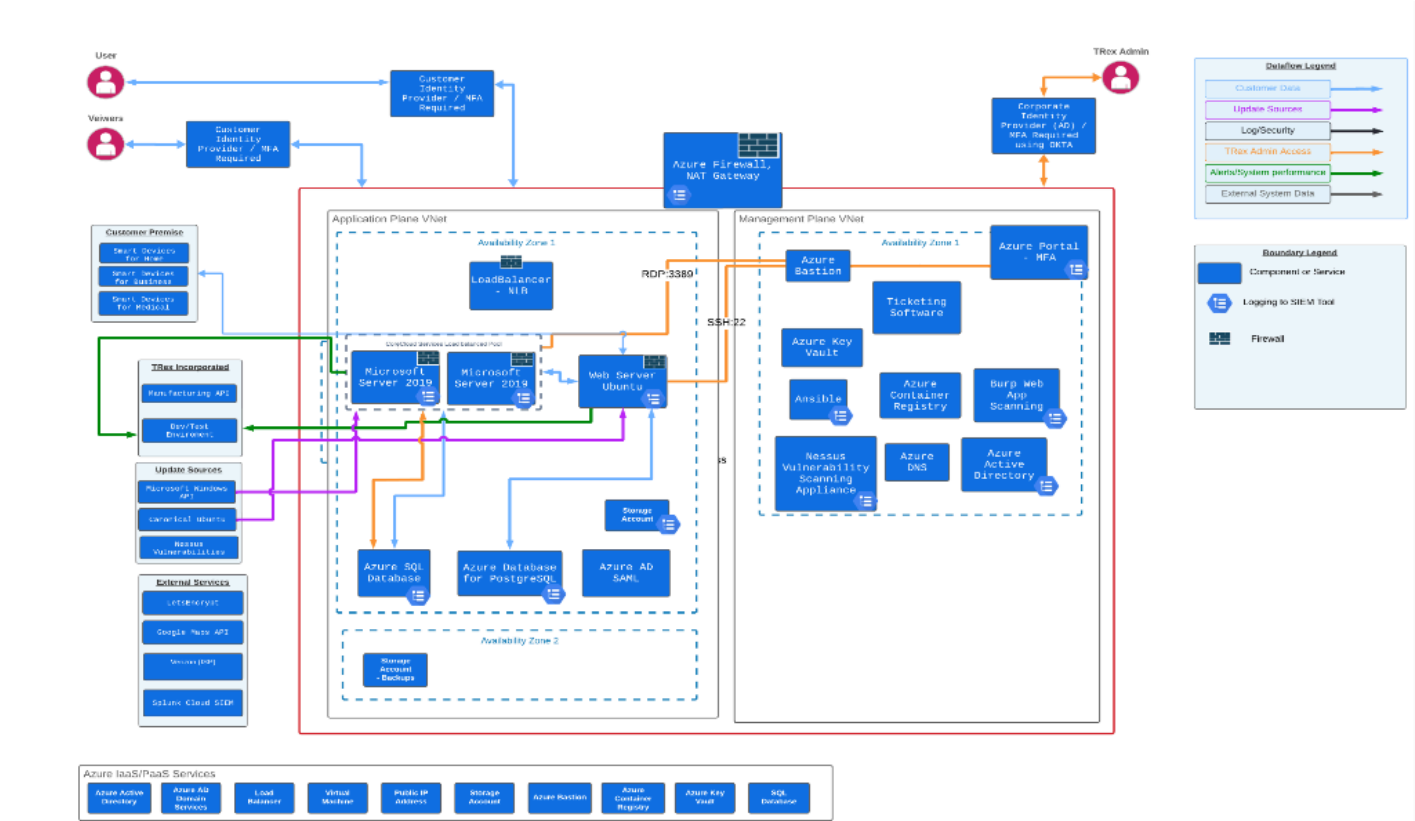


Dataflow

Introduction

There are several dataflows within the TRex SE environment including customer data, update sources, logging/security, TRex administration, alerts, and external system data. The two main dataflows are the customer to devices, devices to TRex SE, and management plane to application plane. Customers interact with their devices through an ISP provider. Although customers can access some offline functionality, there must be an active and stable internet connection for the device to be able to pull and push accurate and current information from TRex SE. Smart devices respond to customer voices, fingerprints, and in the case of medical devices, physical attributes such as heart rate, blood sugar levels, blood pressure, etc. This information, once collected from the customer, is communicated to TRex SE through an encrypted tunnel using FIPS 140-2 validated encryption. TRex SE analyzes the data sent from the device to either warn the user about potentially harmful activities or statistics, or if a certain range will prompt the user to dial 911 immediately, and for some medical devices, the device will use E911 and dial for the customer. For home and business devices, TRex SE may make recommendations based on the customer's use of the device as well as send health statistics of the device itself. For medical devices, TRex SE performs trend analysis to properly baseline the health of the individual using the device. This information is communicated to the user of the device but can also be communicated to authorized users, known as Viewers, of the information that the device produces. TRex admins are responsible for managing the TRex SE application. They perform several security and continuous monitoring activities.

Dataflow Diagram



Assumptions

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
A-0020	TRex SE Platform is not updating security tools promptly. TRex SE,	T-0004 : An external threat actor An external threat actor would have known that GE PACSystems devices contain a	M-0015 : TRex will upgrade Trivy to a supported version and	

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
	credentials used by Trivy is exposed	known denial-of-service vulnerability can overwhelm system resources, which leads to service interruption, resulting in reduced availability of smart devices T-0020 : An external threat actor is bypassing authentication controls can use the exposed credentials to gain unauthorized access to systems and resources, which leads to unauthorized access to sensitive information and security tools, resulting in reduced confidentiality of assets within the trust boundary	enforce least-privilege access controls.	
A-0019	TRex SE is relying on self-signed certificates instead of certificates issued by a trusted certificate authority.	T-0019 : An external threat actor would have known that TRex SE is using self-signed SSL certificates that are not issued by a trusted certificate authority can impersonate a trusted service, which leads to unauthorized disclosure of sensitive information, resulting in reduced confidentiality of customer data	M-0014 : TRex will replace self-signed certificates with trusted CA-issued certificates and implement certificate management procedures to ensure secure and trusted communications.	
A-0018	TRex SE platform has SSH access which is limited to authorized administrators and protected by MFA, encryption, and continuous monitoring.	T-0018 : An external threat actor is intercepting SSH communications can manipulate SSH communications between administrators and the TRex SE platform, which leads to compromised administrative sessions and unauthorized access to sensitive information, resulting in reduced confidentiality and/or integrity of smart devices and TRex SE Platform	M-0013 : TRex will update SSH software to a patched version and restrict SSH access to authorized administrators.	
A-0017	TRex SE's ImageMagick component is being actively managed and monitored.	T-0017 : An external threat actor is executing unauthorized code can exploit vulnerabilities in the ImageMagick component, which leads to disruption of application functionality, resulting in reduced integrity and/or availability of TRex SE Platform	M-0012 : TRex will upgrade ImageMagick to a supported version	

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
A-0016	TRex SE has not consistently updating legacy software components such as Log4j.	T-0016 : An external threat actor would have known that TRex SE is running an outdated version of Log4j and can execute unauthorized code on affected systems, which leads to unauthorized access to systems and sensitive data, resulting in reduced integrity of TRex SE Platform	M-0011 : TRex will replace vulnerable Log4j components, and regularly scanning systems for outdated software	
A-0015	TRex SE is running an outdated version of the Brotli library.	T-0015 : An external threat actor is triggering a denial-of-service and can exploit the vulnerable library to consume excessive system resources, which leads to disruption of services, resulting in reduced integrity of TRex SE Platform	M-0010 : TRex will upgrade the Brotli library to a supported version	
A-0014	TRex SE Platform has insufficient safeguards to prevent unauthorized file access through the web server.	T-0014 : An internal actor is browsing restricted directories and can access files they are not authorized to access, which leads to exposure of sensitive files and application data, resulting in reduced confidentiality and/or integrity of customer data	M-0009 : TRex will implement input validation, restrict file and directory permissions and disable directory browsing	
A-0013	TRex SE Platform has layered security controls, including MFA, FIPS 140-2 validated encryption, and continuous monitoring.	T-0013 : A threat actor is escalating privileges and can intercept or manipulate communications, which leads to unauthorized access to sensitive information, resulting in reduced confidentiality and/or integrity of assets within the trust boundary	M-0008 : TRex will remove unsupported software, and implementing a formal vulnerability management process	
A-0012	TRex SE platform uses stronger, authenticated encryption methods for normal communications for devices.	T-0012 : An external threat actor is performing a man-in-the-middle attack to intercept communications and can exploit weak or unauthenticated encryption methods, which leads to interception or manipulation of communications between medical devices and the TRex SE platform, resulting in reduced confidentiality of medical devices	M-0007 : TRex will enforce strong and authenticated SSL/TLS encryption for all communications within the TRex SE environment.	

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
A-0011	TRex SE has been supported by CGI. TRex SE is protected by existing security measures, including MFA, encryption, centralized logging.	T-0011 : An external threat actor would have known that CGI functionality is enabled within the TRex SE Platform can abuse CGI functionality to perform unauthorized actions, which leads to execution of unintended operations, resulting in reduced integrity of customer data	M-0006 : TRex will disable unnecessary CGI functionality, apply security updates, validate user input and restrict access to CGI resources	
A-0010	TRex SE has controls to detect and mitigate malicious activity related to the Intel Media SDK vulnerabilities before sensitive customer, medical, or device data is affected.	T-0010 : An external threat actor would have known that Intel Media SDK contains known vulnerabilities can exploit vulnerabilities in the Intel Media SDK, which leads to disruption of application, resulting in reduced integrity of medical devices	M-0005 : TRex will apply vendor security updates and remove unsupported Intel Media SDK components where possible	
A-0009	TRex SE has an OpenVPN server without strong authentication.	T-0009 : An external threat actor would have known that the OpenVPN server does not enforce strong authentication mechanisms can gain unauthorized access to the VPN service, which leads to unauthorized access to internal TRex SE resources and sensitive information, resulting in reduced confidentiality of assets within the trust boundary	M-0004 : TRex will enable authentication on the OpenVPN server and MFA for all remote connections.	
A-0008	TRex SE Splunk Management API is accessible over the network, and it is not restricted.	T-0008 : An external threat actor would have known that the Splunk Management API is accessible over the network can access or interact with administrative functions, which leads to unauthorized access to security monitoring information, resulting in reduced integrity of assets within the trust boundary	M-0003 : TRex will limit access to the Splunk Management API to authorized administrators, enforcing multifactor authentication, and restricting network access through firewalls and network segmentation	
A-0007	TRex SE uses untrusted SSL certificate.	T-0007 : An external threat actor would have known that TRex SE uses an untrusted SSL certificate can impersonate the TRex SE platform, which leads to compromising the trust and security of encrypted communications, resulting in	M-0002 : TRex will replace the untrusted SSL certificate with a valid certificate issued by a trusted Certificate Authority	

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
		reduced confidentiality of smart devices		
A-0006	TRex SE is not applying security updates to Splunk in a timely manner. Hence known vulnerabilities remain exposed.	T-0006 : An external threat actor would have known that Splunk is running a vulnerable version that has not been patched can exploit known vulnerabilities in Splunk, which leads to compromise of the logging and monitoring, resulting in reduced confidentiality of TRex SE Platform	M-0001 : TRex will applying Splunk security updates to restricting access through MFA and least-privilege controls.	
A-0005	TRex SE HSTS is not currently enabled, all communications within the TRex environment are already protected using FIPS 140-2 validated encryption and HTTPS	T-0005 : An external threat actor would have known that HSTS is not enabled on the TRex SE HTTPS server can intercept or manipulate web communications, which leads to insecure connections, resulting in reduced confidentiality of customer data	M-0016 : TRex will enable HSTS on all HTTPS servers and enforce secure HTTPS only connections whilst maintaining strong TLS configurations	
A-0004	TRex SE utilizes layered security controls and automated updates to maintain system availability, making it less likely for a denial-of-service		M-0017 : TRex will apply vendor security updates and restrict network exposure through segmentation	
A-0003	TRex ICMP timestamp responses are intentionally enabled to assist administrators with network diagnostics and continuous monitoring for logs in the TRex environment	T-0003 : An external threat actor would have known that ICMP timestamp responses are enabled on the target system. can can gather information they should not be authorized to obtain, which leads to exposure of system date and time information that can assist in reconnaissance activities, resulting in reduced confidentiality of network infrastructure	M-0018 : TRex will disable ICMP timestamp responses and restrict unnecessary ICMP traffic through firewall rules	
A-0002	TRex affected NGINX instance may not be receiving timely security updates. This could expose the TRex environment to attacks that target SSL/TLS communications	T-0002 : An external threat actor would have known that TRex SE NGINX instance may not be receiving timely security updates and can read information they should not be authorized to read, which leads to exposing TRex SE platform to attacks that targets	M-0019 : TRex will Implement timely patch management for NGINX, regularly review SSL/TLS configurations and perform vulnerability scans	

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
		SSL/TLS communication, resulting in reduced confidentiality of smart devices		
A-0001	TRex SE IP forwarding has been enabled, which may create additional security risks if the host is not intended to function as a router or gateway. TRex SE will increase the likelihood of unauthorized network traffic.	T-0001 : An external threat actor would have knowledge that TRex SE has enabled IP forwarding and must know that the host is not intended to function as a router or gateway and can modify the configuration of the API exposed via API Gateway, which leads to unauthorized network traffic, resulting in reduced integrity and/or availability of assets within the trust boundary	M-0020 : TRex will disable unnecessary IP forwarding, restrict API Gateway administrative access and implement network segmentation and firewall rules.	

Threats

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
T-0020	An external threat actor is bypassing authentication controls can use the exposed credentials to gain unauthorized access to systems and resources, which leads to unauthorized access to sensitive information and security tools, resulting in reduced confidentiality of assets within the trust boundary	M-0015 : TRex will upgrade Trivy to a supported version and enforce least-privilege access controls.	A-0020 : TRex SE Platform is not updating security tools promptly. TRex SE, credentials used by Trivy is exposed	Resolved	Medium	I	
T-0019	An external threat actor would have known that TRex SE is using self-signed SSL certificates that	M-0014 : TRex will replace self-signed certificates with trusted CA-issued certificates and	A-0019 : TRex SE is relying on self-signed certificates instead of certificates issued by a	Identified	Medium	R	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	are not issued by a trusted certificate authority can impersonate a trusted service, which leads to unauthorized disclosure of sensitive information, resulting in reduced confidentiality of customer data	implement certificate management procedures to ensure secure and trusted communications.	trusted certificate authority.				
T-0018	An external threat actor is intercepting SSH communications can manipulate SSH communications between administrators and the TRex SE platform, which leads to compromised administrative sessions and unauthorized access to sensitive information, resulting in reduced confidentiality and/or integrity of smart devices and TRex SE Platform	M-0013 : TRex will update SSH software to a patched version and restrict SSH access to authorized administrators.	A-0018 : TRex SE platform has SSH access which is limited to authorized administrators and protected by MFA, encryption, and continuous monitoring.	Identified	Medium	D, E, I	
T-0017	An external threat actor is executing unauthorized code can exploit vulnerabilities in the ImageMagick component, which leads to disruption of application functionality, resulting in	M-0012 : TRex will upgrade ImageMagick to a supported version	A-0017 : TRex SE's ImageMagick component is being actively managed and monitored.	Resolved	High	D	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	reduced integrity and/or availability of TRex SE Platform						
T-0016	An external threat actor would have known that TRex SE is running an outdated version of Log4j and can execute unauthorized code on affected systems, which leads to unauthorized access to systems and sensitive data, resulting in reduced integrity of TRex SE Platform	M-0011 : TRex will replace vulnerable Log4j components, and regularly scanning systems for outdated software	A-0016 : TRex SE has not consistently updating legacy software components such as Log4j.	Resolved	High	D	
T-0015	An external threat actor is triggering a denial-of-service and can exploit the vulnerable library to consume excessive system resources, which leads to disruption of services, resulting in reduced integrity of TRex SE Platform	M-0010 : TRex will upgrade the Brotli library to a supported version	A-0015 : TRex SE is running an outdated version of the Brotli library.	Identified	High	D	
T-0014	An internal actor is browsing restricted directories and can access files they are not authorized to access, which leads to exposure of sensitive files and application	M-0009 : TRex will implement input validation, restrict file and directory permissions and disable directory browsing	A-0014 : TRex SE Platform has insufficient safeguards to prevent unauthorized file access through the web server.	Resolved	High	I, E	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	data, resulting in reduced confidentiality and/or integrity of customer data						
T-0013	A threat actor is escalating privileges and can intercept or manipulate communications, which leads to unauthorized access to sensitive information, resulting in reduced confidentiality and/or integrity of assets within the trust boundary	M-0008 : TRex will remove unsupported software, and implementing a formal vulnerability management process	A-0013 : TRex SE Platform has layered security controls, including MFA, FIPS 140-2 validated encryption, and continuous monitoring.	Resolved	Medium	I, E	
T-0012	An external threat actor is performing a man-in-the-middle attack to intercept communications and can exploit weak or unauthenticated encryption methods, which leads to interception or manipulation of communications between medical devices and the TRex SE platform, resulting in reduced confidentiality of medical devices	M-0007 : TRex will enforce strong and authenticated SSL/TLS encryption for all communications within the TRex SE environment.	A-0012 : TRex SE platform uses stronger, authenticated encryption methods for normal communications for devices.	Resolved	Medium	I	
T-0011	An external threat actor would have known that CGI functionality is enabled within	M-0006 : TRex will disable unnecessary CGI functionality, apply security updates,	A-0011 : TRex SE has been supported by CGI. TRex SE is protected by existing security	Identified	High	D	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	the TRex SE Platform can abuse CGI functionality to perform unauthorized actions, which leads to execution of unintended operations, resulting in reduced integrity of customer data	validate user input and restrict access to CGI resources	measures, including MFA, encryption, centralized logging.				
T-0010	An external threat actor would have known that Intel Media SDK contains known vulnerabilities can can exploit vulnerabilities in the Intel Media SDK, which leads to disruption of application, resulting in reduced integrity of medical devices	M-0005 : TRex will apply vendor security updates and remove unsupported Intel Media SDK components where possible	A-0010 : TRex SE has controls to detect and mitigate malicious activity related to the Intel Media SDK vulnerabilities before sensitive customer, medical, or device data is affected.	Resolved	High	D, I	
T-0009	An external threat actor would have known that the OpenVPN server does not enforce strong authentication mechanisms can gain unauthorized access to the VPN service, which leads to unauthorized access to internal TRex SE resources and sensitive information, resulting in reduced	M-0004 : TRex will enable authentication on the OpenVPN server and MFA for all remote connections.	A-0009 : TRex SE has an OpenVPN server without strong authentication.	Resolved	High	I, D	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	confidentiality of assets within the trust boundary						
T-0008	An external threat actor would have known that the Splunk Management API is accessible over the network can access or interact with administrative functions, which leads to unauthorized access to security monitoring information, resulting in reduced integrity of assets within the trust boundary	M-0003 : TRex will limit access to the Splunk Management API to authorized administrators, enforcing multifactor authentication, and restricting network access through firewalls and network segmentation	A-0008 : TRex SE Splunk Management API is accessible over the network, and it is not restricted.	Resolved	High	D	
T-0007	An external threat actor would have known that TRex SE uses an untrusted SSL certificate can impersonate the TRex SE platform, which leads to compromising the trust and security of encrypted communications, resulting in reduced confidentiality of smart devices	M-0002 : TRex will replace the untrusted SSL certificate with a valid certificate issued by a trusted Certificate Authority	A-0007 : TRex SE uses untrusted SSL certificate.	Resolved	Medium	E	
T-0006	An external threat actor would have known that Splunk is running a vulnerable	M-0001 : TRex will applying Splunk security updates to restricting access through MFA and least-	A-0006 : TRex SE is not applying security updates to Splunk in a timely manner. Hence known	Identified	Low	I	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	version that has not been patched can exploit known vulnerabilities in Splunk, which leads to compromise of the logging and monitoring, resulting in reduced confidentiality of TRex SE Platform	privilege controls.	vulnerabilities remain exposed.				
T-0005	An external threat actor would have known that HSTS is not enabled on the TRex SE HTTPS server can intercept or manipulate web communications, which leads to insecure connections, resulting in reduced confidentiality of customer data	M-0016 : TRex will enable HSTS on all HTTPS servers and enforce secure HTTPS only connections whilst maintaining strong TLS configurations	A-0005 : TRex SE HSTS is not currently enabled, all communications within the TRex environment are already protected using FIPS 140-2 validated encryption and HTTPS	Identified	Low	I	
T-0004	An external threat actor An external threat actor would have known that GE PACSystems devices contain a known denial-of-service vulnerability can overwhelm system resources, which leads to service interruption, resulting in reduced availability of smart devices	M-0017 : TRex will apply vendor security updates and restrict network exposure through segmentation	A-0020 : TRex SE Platform is not updating security tools promptly. TRex SE, credentials used by Trivy is exposed	Identified	High	D	
T-0003	An external threat actor would have	M-0018 : TRex will disable ICMP timestamp	A-0003 : TRex ICMP timestamp responses are	Identified	Low	I	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	known that ICMP timestamp responses are enabled on the target system. can can gather information they should not be authorized to obtain, which leads to exposure of system date and time information that can assist in reconnaissance activities, resulting in reduced confidentiality of network infrastructure	responses and restrict unnecessary ICMP traffic through firewall rules	intentionally enabled to assist administrators with network diagnostics and continuous monitoring for logs in the TRex environment				
T-0002	An external threat actor would have known that TRex SE NGINX instance may not be receiving timely security updates and can read information they should not be authorized to read, which leads to exposing TRex SE platform to attacks that targets SSL/TLS communication, resulting in reduced confidentiality of smart devices	M-0019 : TRex will Implement timely patch management for NGINX, regularly review SSL/TLS configurations and perform vulnerability scans	A-0002 : TRex affected NGINX instance may not be receiving timely security updates. This could expose the TRex environment to attacks that target SSL/TLS communications	Identified	Medium	I, D	
T-0001	An external threat actor would have knowledge that TRex SE has enabled IP forwarding and must know that the host is not	M-0020 : TRex will disable unnecessary IP forwarding, restrict API Gateway administrative access and implement	A-0001 : TRex SE IP forwarding has been enabled, which may create additional security risks if the host is not intended to	Identified	Medium	D	

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	intended to function as a router or gateway and can modify the configuration of the API exposed via API Gateway, which leads to unauthorized network traffic, resulting in reduced integrity and/or availability of assets within the trust boundary	network segmentation and firewall rules.	function as a router or gateway. TRex SE will increase the likelihood of unauthorized network traffic.				

Mitigations

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
M-0020	TRex will disable unnecessary IP forwarding, restrict API Gateway administrative access and implement network segmentation and firewall rules.	T-0001 : An external threat actor would have knowledge that TRex SE has enabled IP forwarding and must know that the host is not intended to function as a router or gateway and can modify the configuration of the API exposed via API Gateway, which leads to unauthorized network traffic, resulting in reduced integrity and/or availability of assets within the trust boundary	A-0001 : TRex SE IP forwarding has been enabled, which may create additional security risks if the host is not intended to function as a router or gateway. TRex SE will increase the likelihood of unauthorized network traffic.	Identified	
M-0019	TRex will Implement timely patch management for NGINX, regularly review SSL/TLS configurations and perform vulnerability scans	T-0002 : An external threat actor would have known that TRex SE NGINX instance may not be receiving timely security updates and can read information they should not be authorized to read, which leads to exposing TRex SE platform to attacks that targets SSL/TLS communication, resulting	A-0002 : TRex affected NGINX instance may not be receiving timely security updates. This could expose the TRex environment to attacks that target SSL/TLS communications	Identified	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
		in reduced confidentiality of smart devices			
M-0018	TRex will disable ICMP timestamp responses and restrict unnecessary ICMP traffic through firewall rules	T-0003 : An external threat actor would have known that ICMP timestamp responses are enabled on the target system. can can gather information they should not be authorized to obtain, which leads to exposure of system date and time information that can assist in reconnaissance activities, resulting in reduced confidentiality of network infrastructure	A-0003 : TRex ICMP timestamp responses are intentionally enabled to assist administrators with network diagnostics and continuous monitoring for logs in the TRex environment	Identified	
M-0017	TRex will apply vendor security updates and restrict network exposure through segmentation	T-0004 : An external threat actor An external threat actor would have known that GE PACSystems devices contain a known denial-of-service vulnerability can overwhelm system resources, which leads to service interruption, resulting in reduced availability of smart devices	A-0004 : TRex SE utilizes layered security controls and automated updates to maintain system availability, making it less likely for a denial-of-service	Identified	
M-0016	TRex will enable HSTS on all HTTPS servers and enforce secure HTTPS only connections whilst maintaining strong TLS configurations	T-0005 : An external threat actor would have known that HSTS is not enabled on the TRex SE HTTPS server can intercept or manipulate web communications, which leads to insecure connections, resulting in reduced confidentiality of customer data	A-0005 : TRex SE HSTS is not currently enabled, all communications within the TRex environment are already protected using FIPS 140-2 validated encryption and HTTPS	Identified	
M-0015	TRex will upgrade Trivy to a supported version and enforce least-privilege access controls.	T-0020 : An external threat actor is bypassing authentication controls can use the exposed credentials to gain unauthorized access to systems and resources, which leads to unauthorized access to sensitive information and	A-0020 : TRex SE Platform is not updating security tools promptly. TRex SE, credentials used by Trivy is exposed	Identified	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
		security tools, resulting in reduced confidentiality of assets within the trust boundary			
M-0014	TRex will replace self-signed certificates with trusted CA-issued certificates and implement certificate management procedures to ensure secure and trusted communications.	T-0019 : An external threat actor would have known that TRex SE is using self-signed SSL certificates that are not issued by a trusted certificate authority can impersonate a trusted service, which leads to unauthorized disclosure of sensitive information, resulting in reduced confidentiality of customer data	A-0019 : TRex SE is relying on self-signed certificates instead of certificates issued by a trusted certificate authority.	Identified	
M-0013	TRex will update SSH software to a patched version and restrict SSH access to authorized administrators.	T-0018 : An external threat actor is intercepting SSH communications can manipulate SSH communications between administrators and the TRex SE platform, which leads to compromised administrative sessions and unauthorized access to sensitive information, resulting in reduced confidentiality and/or integrity of smart devices and TRex SE Platform	A-0018 : TRex SE platform has SSH access which is limited to authorized administrators and protected by MFA, encryption, and continuous monitoring.	Identified	
M-0012	TRex will upgrade ImageMagick to a supported version	T-0017 : An external threat actor is executing unauthorized code can exploit vulnerabilities in the ImageMagick component, which leads to disruption of application functionality, resulting in reduced integrity and/or availability of TRex SE Platform	A-0017 : TRex SE's ImageMagick component is being actively managed and monitored.	Identified	
M-0011	TRex will replace vulnerable Log4j components, and regularly scanning systems for outdated software	T-0016 : An external threat actor would have known that TRex SE is running an outdated version of Log4j and can execute unauthorized	A-0016 : TRex SE has not consistently updating legacy software components such as Log4j.	Identified	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
		code on affected systems, which leads to unauthorized access to systems and sensitive data, resulting in reduced integrity of TRex SE Platform			
M-0010	TRex will upgrade the Brotli library to a supported version	T-0015 : An external threat actor is triggering a denial-of-service and can exploit the vulnerable library to consume excessive system resources, which leads to disruption of services, resulting in reduced integrity of TRex SE Platform	A-0015 : TRex SE is running an outdated version of the Brotli library.	Identified	
M-0009	TRex will implement input validation, restrict file and directory permissions and disable directory browsing	T-0014 : An internal actor is browsing restricted directories and can access files they are not authorized to access, which leads to exposure of sensitive files and application data, resulting in reduced confidentiality and/or integrity of customer data	A-0014 : TRex SE Platform has insufficient safeguards to prevent unauthorized file access through the web server.	Identified	
M-0008	TRex will remove unsupported software, and implementing a formal vulnerability management process	T-0013 : A threat actor is escalating privileges and can intercept or manipulate communications, which leads to unauthorized access to sensitive information, resulting in reduced confidentiality and/or integrity of assets within the trust boundary	A-0013 : TRex SE Platform has layered security controls, including MFA, FIPS 140-2 validated encryption, and continuous monitoring.	Identified	
M-0007	TRex will enforce strong and authenticated SSL/TLS encryption for all communications within the TRex SE environment.	T-0012 : An external threat actor is performing a man-in-the-middle attack to intercept communications and can exploit weak or unauthenticated encryption methods, which leads to interception or manipulation of	A-0012 : TRex SE platform uses stronger, authenticated encryption methods for normal communications for devices.	Identified	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
		communications between medical devices and the TRex SE platform, resulting in reduced confidentiality of medical devices			
M-0006	TRex will disable unnecessary CGI functionality, apply security updates, validate user input and restrict access to CGI resources	<u>T-0011</u> : An external threat actor would have known that CGI functionality is enabled within the TRex SE Platform can abuse CGI functionality to perform unauthorized actions, which leads to execution of unintended operations, resulting in reduced integrity of customer data	<u>A-0011</u> : TRex SE has been supported by CGI. TRex SE is protected by existing security measures, including MFA, encryption, centralized logging.	Identified	
M-0005	TRex will apply vendor security updates and remove unsupported Intel Media SDK components where possible	<u>T-0010</u> : An external threat actor would have known that Intel Media SDK contains known vulnerabilities can exploit vulnerabilities in the Intel Media SDK, which leads to disruption of application, resulting in reduced integrity of medical devices	<u>A-0010</u> : TRex SE has controls to detect and mitigate malicious activity related to the Intel Media SDK vulnerabilities before sensitive customer, medical, or device data is affected.	Identified	
M-0004	TRex will enable authentication on the OpenVPN server and MFA for all remote connections.	<u>T-0009</u> : An external threat actor would have known that the OpenVPN server does not enforce strong authentication mechanisms can gain unauthorized access to the VPN service, which leads to unauthorized access to internal TRex SE resources and sensitive information, resulting in reduced confidentiality of assets within the trust boundary	<u>A-0009</u> : TRex SE has an OpenVPN server without strong authentication.	Identified	
M-0003	TRex will limit access to the Splunk Management API to authorized administrators, enforcing multifactor authentication, and	<u>T-0008</u> : An external threat actor would have known that the Splunk Management API is accessible over the network can access or interact with	<u>A-0008</u> : TRex SE Splunk Management API is accessible over the network, and it is not restricted.	Identified	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
	restricting network access through firewalls and network segmentation	administrative functions, which leads to unauthorized access to security monitoring information, resulting in reduced integrity of assets within the trust boundary			
M-0002	TRex will replace the untrusted SSL certificate with a valid certificate issued by a trusted Certificate Authority	T-0007 : An external threat actor would have known that TRex SE uses an untrusted SSL certificate can impersonate the TRex SE platform, which leads to compromising the trust and security of encrypted communications, resulting in reduced confidentiality of smart devices	A-0007 : TRex SE uses untrusted SSL certificate.	Identified	
M-0001	TRex will applying Splunk security updates to restricting access through MFA and least-privilege controls.	T-0006 : An external threat actor would have known that Splunk is running a vulnerable version that has not been patched can exploit known vulnerabilities in Splunk, which leads to compromise of the logging and monitoring, resulting in reduced confidentiality of TRex SE Platform	A-0006 : TRex SE is not applying security updates to Splunk in a timely manner. Hence known vulnerabilities remain exposed.	Identified	

Impacted Assets

Assets Number	Asset	Related Threats
AS-0001	assets within the trust boundary	T-0020: An external threat actor is bypassing authentication controls can use the exposed credentials to gain unauthorized access to systems and resources, which leads to unauthorized access to sensitive information and security tools, resulting in reduced confidentiality of assets within the trust boundary T-0013: A threat actor is escalating privileges and can intercept or manipulate communications, which leads to unauthorized access to sensitive information, resulting in reduced confidentiality and/or integrity of assets within the trust boundary T-0009: An external threat actor would have known that the OpenVPN server does not enforce strong authentication mechanisms can gain unauthorized access to the VPN service, which leads to unauthorized access to internal TRex SE resources and sensitive information, resulting in reduced confidentiality of assets within the trust boundary

Assets Number	Asset	Related Threats
		T-0008: An external threat actor would have known that the Splunk Management API is accessible over the network can access or interact with administrative functions, which leads to unauthorized access to security monitoring information, resulting in reduced integrity of assets within the trust boundary T-0001: An external threat actor would have knowledge that TRex SE has enabled IP forwarding and must know that the host is not intended to function as a router or gateway and can modify the configuration of the API exposed via API Gateway, which leads to unauthorized network traffic, resulting in reduced integrity and/or availability of assets within the trust boundary
AS-0002	customer data	T-0019: An external threat actor would have known that TRex SE is using self-signed SSL certificates that are not issued by a trusted certificate authority can impersonate a trusted service, which leads to unauthorized disclosure of sensitive information, resulting in reduced confidentiality of customer data T-0014: An internal actor is browsing restricted directories and can access files they are not authorized to access, which leads to exposure of sensitive files and application data, resulting in reduced confidentiality and/or integrity of customer data T-0011: An external threat actor would have known that CGI functionality is enabled within the TRex SE Platform can abuse CGI functionality to perform unauthorized actions, which leads to execution of unintended operations, resulting in reduced integrity of customer data T-0005: An external threat actor would have known that HSTS is not enabled on the TRex SE HTTPS server can intercept or manipulate web communications, which leads to insecure connections, resulting in reduced confidentiality of customer data
AS-0003	smart devices	T-0018: An external threat actor is intercepting SSH communications can manipulate SSH communications between administrators and the TRex SE platform, which leads to compromised administrative sessions and unauthorized access to sensitive information, resulting in reduced confidentiality and/or integrity of smart devices and TRex SE Platform T-0007: An external threat actor would have known that TRex SE uses an untrusted SSL certificate can impersonate the TRex SE platform, which leads to compromising the trust and security of encrypted communications, resulting in reduced confidentiality of smart devices T-0004: An external threat actor An external threat actor would have known that GE PACSystems devices contain a known denial-of-service vulnerability can overwhelm system resources, which leads to service interruption, resulting in reduced availability of smart devices T-0002: An external threat actor would have known that TRex SE NGINX instance may not be receiving timely security updates and can read information they should not be authorized to read, which leads to exposing TRex SE platform to attacks that targets SSL/TLS communication, resulting in reduced confidentiality of smart devices
AS-0004	TRex SE Platform	T-0018: An external threat actor is intercepting SSH communications can manipulate SSH communications between administrators and the TRex SE platform, which leads to compromised administrative sessions and unauthorized access to sensitive information, resulting in reduced confidentiality and/or integrity of smart devices and TRex SE Platform T-0017: An external threat actor is executing unauthorized code can exploit vulnerabilities in the ImageMagick component, which leads to disruption of application functionality, resulting in reduced integrity and/or availability of TRex SE Platform T-0016: An external threat actor would have known that TRex SE is running an outdated version of Log4j and can execute unauthorized code on affected systems, which leads to unauthorized access to systems and sensitive data, resulting in

Assets Number	Asset	Related Threats
		reduced integrity of TRex SE Platform T-0015: An external threat actor is triggering a denial-of-service and can exploit the vulnerable library to consume excessive system resources, which leads to disruption of services, resulting in reduced integrity of TRex SE Platform T-0006: An external threat actor would have known that Splunk is running a vulnerable version that has not been patched can exploit known vulnerabilities in Splunk, which leads to compromise of the logging and monitoring, resulting in reduced confidentiality of TRex SE Platform
AS-0005	medical devices	T-0012: An external threat actor is performing a man-in-the-middle attack to intercept communications and can exploit weak or unauthenticated encryption methods, which leads to interception or manipulation of communications between medical devices and the TRex SE platform, resulting in reduced confidentiality of medical devices T-0010: An external threat actor would have known that Intel Media SDK contains known vulnerabilities can can exploit vulnerabilities in the Intel Media SDK, which leads to disruption of application, resulting in reduced integrity of medical devices
AS-0006	network infrastructure	T-0003: An external threat actor would have known that ICMP timestamp responses are enabled on the target system. can can gather information they should not be authorized to obtain, which leads to exposure of system date and time information that can assist in reconnaissance activities, resulting in reduced confidentiality of network infrastructure